



HSPS 班級點數銀行
CLASS POINT BANK

TEST REPORT · 測試紀錄

HSPS 點數銀行 測試紀錄

功能測試 · 整合測試 · 端對端測試 · 安全測試

執行時間 2026/09/27 04:00

受測版本 v1.0.0 (Firebase 正式版 + 模擬資料庫)

對應文件 PRD v1.3 、 SDD v1.4

總結 204 / 204 項通過 · 無失敗



1 總覽

204/204 全部測試通過	114/114 模擬資料庫：Vitest + 端對端 (14 情境 × 2 環境)	90/90 Firebase 模擬器：規則 + 整合 + 端對端	1/1 嚴重 / 高風險套件漏洞
--------------------------------------	---	--	--

類別	範圍	項目	結果
單元測試	金額、日期、收款碼、名冊解析、帳本計算	18	通過
整合測試	批次停用、啟用與刪除學生帳號；加扣點、批次、小組獎勵、沖正、對帳；帳號、登入、密碼；QR 轉帳送出與審核	53	通過
安全測試	原子性 (全有全無 · BR-17) ； 權限矩陣 (對應 SDD 7.2)	15	通過
端對端測試	以正式建置版 (含 CSP) 在桌面 Chromium (教師電腦) 與 iPad Pro 11 橫向 WebKit (學生 iPad Safari) 執行完整操作流程	28	通過
Firebase 模擬器	30 項權限規則直接測試；與模擬版相同的整合測試改對 Firebase + 正式規則執行 (10 項僅適用模擬資料庫而略過) ；端對端以獨立瀏覽器模擬多台裝置	90	通過
型別檢查與建置	vue-tsc 型別檢查、vite 正式建置 (Firebase 版)	2	通過
相依套件稽核	npm audit (正式執行套件 / 開發工具)	1	失敗

1.1 測試環境

項目	版本 / 設定
作業系統	Windows 10 Pro Education
Node.js	v24.18.0
Vue / Vite	3.5.43 / 6.4.3
Vitest (jsdom)	3.2.7
Playwright	1.63.0 ; desktop-chromium (1366×900) 、ipad-webkit (iPad Pro 11 landscape)
資料庫	① 模擬資料庫 (瀏覽器 localStorage) ② Firebase 模擬器 (Auth + Firestore · 套用正式 firestore.rules)
測試資料	全部為虛構姓名與帳號，未使用真實學生名冊

2 需求對照 (PRD 驗收情境)

#	PRD 13.2 驗收情境	驗證的測試
1	匯入名冊，其中有錯誤列	E2E 「首次使用...匯入名冊 (含錯誤列預覽) 」；單元「標示錯誤列...」
2	批次全班加點	整合「批次加點：每人一筆交易，共用批次編號」；E2E 各情境前置
3	小組獎勵：兩組並列冠軍、一組亞軍、一人請假	整合「並列冠軍 + 亞軍 + 請假排除」；E2E 「小組獎勵...」
4	學生 A 收款、B 付款 → 雙方審核中、餘額不變	整合「送出後為審核中，雙方餘額都不變」；E2E 「QR 轉帳完整流程」
5	同一張 QR 截圖再付一次	整合「收款碼只能使用一次」；E2E 「同一個收款碼不能用兩次」
6	老師核准 → 雙方餘額與明細更新	整合「核准後付款人扣點...」；E2E 「QR 轉帳完整流程」
7	多筆申請總額超過餘額	整合「多筆申請總額超過餘額...」「核准所選...」
8	老師沖正	整合「沖正產生反向交易...」「沖正轉帳：雙方餘額還原...」；E2E 「個別加扣點 → 沖正」
9	學生開啟教師網址	E2E 「權限：學生無法進入教師後台」；安全「竄改登入身分」
10	對帳檢查	整合「對帳：經過各種操作後...」；E2E 對帳全部一致
11	學生在電腦上以輸入代碼付款	E2E (desktop-chromium 無鏡頭 → 預設輸入代碼)
12	送出或核准中途斷線	安全「原子性：中途失敗時資料不變」4 項
13	轉帳雙方看到相同細目、看不到對方餘額	整合「付款人與收款人都看得到...」「交易資料中不含任何餘額資訊」；E2E 詳情頁比對
14	老師新增小確幸並顯示於前台	E2E 「小確幸：老師新增...」；安全「只看得到啟用且顯示於前台的項目」

3 端對端測試 (Playwright)

每個情境都從全新瀏覽器開始：建立教師帳號 → 匯入虛構名冊 → 以多個分頁模擬老師與不同學生同時操作。

情境	桌面 Chromium	iPad WebKit
首次使用：建立教師帳號 → 匯入名冊 (含錯誤列預覽) → 學生登入 01-setup-login.spec.ts	通過 4.3 秒	通過 17.0 秒
權限：學生無法進入教師後台；未登入會被導向登入頁 01-setup-login.spec.ts	通過 3.3 秒	通過 12.8 秒
教師登出後重新登入；停用的學生無法登入 01-setup-login.spec.ts	通過 4.5 秒	通過 17.2 秒
QR 轉帳完整流程：收款 → 輸入代碼付款 → 雙方即時看到 → 教師核准 → 雙方明細一致 02-transfer.spec.ts	通過 8.1 秒	通過 62.5 秒
同一個收款碼不能用兩次；不能付款給自己 02-transfer.spec.ts	通過 8.4 秒	通過 68.8 秒
付款金額超過餘額時無法送出；教師駁回後學生看得到原因 02-transfer.spec.ts	通過 6.9 秒	通過 43.8 秒
小組獎勵：並列冠軍 + 亞軍 + 請假排除；同日重複提醒；整批沖正 03-teacher.spec.ts	通過 6.2 秒	通過 38.7 秒
個別加扣點 (一鍵項目) → 交易紀錄沖正 → 學生看到已沖正；對帳一致 03-teacher.spec.ts	通過 6.0 秒	通過 20.1 秒
批次扣點時有人點數不足：顯示名單並可排除後再送出 03-teacher.spec.ts	通過 3.3 秒	通過 10.4 秒
小確幸：老師新增並顯示於前台 → 學生即時看到；隱藏後消失 03-teacher.spec.ts	通過 4.2 秒	通過 18.2 秒
儀表板與分組管理畫面 03-teacher.spec.ts	通過 3.3 秒	通過 10.7 秒
安全：正式版含 CSP；事由中的 HTML / 腳本以純文字顯示 (XSS 防護) 04-security.spec.ts	通過 5.8 秒	通過 38.7 秒
安全：竄改瀏覽器中的登入身分無法取得教師權限 04-security.spec.ts	通過 3.1 秒	通過 11.7 秒
學生總覽：批次停用、批次刪除 (需輸入「刪除」確認)；交易紀錄保留 05-students-bulk.spec.ts	通過 7.5 秒	通過 56.9 秒

說明

Windows 上的 Playwright WebKit 執行速度明顯較慢（同一情境約為 Chromium 的 5~8 倍），因此 iPad 專案的逾時設為 150 秒；真實 iPad Safari 不受影響。上線前仍需以真實 iPad 進行實機驗收（相機權限、加入主畫面、校園網路）。

4 單元、整合與安全測試 (Vitest)

整合測試：批次停用、啟用與刪除學生帳號

分組	測試項目	結果	毫秒
批次停用 / 啟用與刪除學生帳號	批次停用後無法登入，批次啟用後恢復	通過	17
批次停用 / 啟用與刪除學生帳號	批次刪除：帳號與登入資料移除，已登入的裝置立即失效	通過	10
批次停用 / 啟用與刪除學生帳號	刪除後交易紀錄保留：對方明細仍看得到姓名與座號；對帳仍一致	通過	12
批次停用 / 啟用與刪除學生帳號	刪除時自動駁回相關的審核中轉帳，並回報被刪除的點數	通過	9
批次停用 / 啟用與刪除學生帳號	刪除學生的收款碼一併失效	通過	6
批次停用 / 啟用與刪除學生帳號	批次刪除全有全無：清單中有不存在的學生時，整批都不刪	通過	5
批次停用 / 啟用與刪除學生帳號	不能用刪除學生的操作刪除教師帳號	通過	4
批次停用 / 啟用與刪除學生帳號	刪除後可用同一帳號重新匯入（例如名冊打錯重建）	通過	7

整合測試：加扣點、批次、小組獎勵、沖正、對帳

分組	測試項目	結果	毫秒
加扣點與批次	個別加點與扣點	通過	14
加扣點與批次	批次加點：每人一筆交易，共用批次編號	通過	6
加扣點與批次	批次扣點時有人點數不足：整批不執行，並列出不足名單	通過	6
加扣點與批次	金額與項目名稱驗證	通過	8
小組獎勵	並列冠軍 + 亞軍 + 請假排除	通過	8
小組獎勵	同一組不能同時是冠軍和亞軍	通過	6
小組獎勵	同一天重複發放需要確認	通過	5
小組獎勵	整批沖正後可以同日重新發放，餘額全部還原	通過	8

沖正	沖正產生反向交易，原交易標記已沖正	通過	7
沖正	同一筆不能沖正兩次；沖正交易不能再沖正；審核中不能沖正	通過	9
沖正	沖正轉帳：收款人已把點數花掉時，阻擋沖正（避免負數）	通過	9
沖正	沖正轉帳：雙方餘額還原，雙方都看得到沖正紀錄	通過	9
沖正	對帳：經過各種操作後，每位學生交易加總 = 餘額	通過	19

安全測試：原子性（全有全無，BR-17）

分組	測試項目	結果	毫秒
原子性：中途失敗時資料不變	送出轉帳：交易與收款碼標記都不會只完成一半	通過	21
原子性：中途失敗時資料不變	核准轉帳：不會出現「付款人扣了、收款人沒加」	通過	8
原子性：中途失敗時資料不變	批次加點、小組獎勵、整批沖正	通過	10
原子性：中途失敗時資料不變	業務規則失敗（例如餘額不足）同樣不留下任何部分結果	通過	5

整合測試：帳號、登入、密碼

分組	測試項目	結果	毫秒
帳號與登入	全新系統需要先建立教師帳號，且只能建立一次	通過	9
帳號與登入	建立教師時自動產生 8 個組別與預設加點項目、小確幸	通過	5
帳號與登入	學生以帳號密碼登入；帳號不分大小寫	通過	7
帳號與登入	帳號與密碼的全形英數視同半形（中文輸入法）	通過	7
帳號與登入	模擬資料庫診斷：回報學生數與帳號是否存在於此瀏覽器	通過	6
帳號與登入	密碼錯誤與帳號不存在顯示相同訊息（不透露哪一項錯）	通過	6
帳號與登入	連續輸錯 5 次鎖定 1 分鐘	通過	11
帳號與登入	停用的帳號不能登入，已登入者下一次操作即被拒絕	通過	11
帳號與登入	學生可以修改自己的密碼（需舊密碼）	通過	12
帳號與登入	老師可以重設學生密碼，並解除鎖定（Firebase 版需用管理工具）	通過	12
帳號與登入	匯入名冊：已存在的帳號略過，密碼以雜湊保存（資料庫中沒有明文）	通過	9
帳號與登入	登出後不能再讀取資料	通過	12

安全測試：權限矩陣（對應 SDD 7.2）

分組	測試項目	結果	毫秒
權限：未登入	未登入讀取任何資料皆被拒絕	通過	12
權限：未登入	偽造 session (不存在的 uid) 被拒絕	通過	4
權限：未登入	學生竊改 session 的 role 為 teacher 仍無教師權限 (以資料庫角色為準)	通過	5
權限：學生不能執行教師操作	所有教師專用方法都拒絕學生	通過	13
權限：學生不能執行教師操作	教師不能使用學生的收付款功能	通過	4
權限：學生之間的資料隔離	學生看不到與自己無關的交易	通過	12
權限：學生之間的資料隔離	學生只拿得到自己的帳戶資料	通過	5
權限：學生之間的資料隔離	學生不能取消別人的收款碼	通過	11
權限：加點項目與小確幸的可見性	學生只看得到「啟用」且「顯示於前台」的項目	通過	8
資料保存	匯出資料不含密碼雜湊	通過	8
資料保存	沒有任何刪除交易的操作介面 (帳本只增不刪) ；唯一的刪除操作是刪除學生帳號	通過	4

整合測試：QR 轉帳送出與審核

分組	測試項目	結果	毫秒
QR 轉帳：送出申請	收款碼為 8 碼、預設 3 分鐘有效	通過	15
QR 轉帳：送出申請	送出後為審核中，雙方餘額都不變	通過	9
QR 轉帳：送出申請	付款人與收款人都看得到同一筆交易的完整細目 (對象、事由、金額、狀態)	通過	12
QR 轉帳：送出申請	交易資料中不含任何餘額資訊 (保護隱私)	通過	9
QR 轉帳：送出申請	收款碼只能使用一次 (截圖轉傳無效)	通過	9
QR 轉帳：送出申請	收款碼過期後無法使用	通過	8
QR 轉帳：送出申請	收款人離開頁面時取消收款碼，之後無法使用	通過	7
QR 轉帳：送出申請	不存在或格式錯誤的代碼	通過	9
QR 轉帳：送出申請	手動輸入代碼可忽略大小寫與空白	通過	6

QR 轉帳：送出申請	不能付款給自己	通過	9
QR 轉帳：送出申請	金額必須是正整數且不超過餘額	通過	14
QR 轉帳：送出申請	分類必選、事由必填且最多 50 字	通過	6
QR 轉帳：送出申請	失敗的申請不會消耗收款碼（全有全無）	通過	7
QR 轉帳：送出申請	收款人帳號被停用時無法付款給他	通過	8
QR 轉帳：教師審核	核准後付款人扣點、收款人加點、狀態為已完成	通過	7
QR 轉帳：教師審核	同一筆重複核准只生效一次	通過	9
QR 轉帳：教師審核	兩台教師裝置同時核准同一筆，只成功一次	通過	8
QR 轉帳：教師審核	多筆申請總額超過餘額：逐筆核准，到餘額不足那筆被擋下	通過	9
QR 轉帳：教師審核	核准所選：依送出順序逐筆處理並回報各自結果	通過	8
QR 轉帳：教師審核	駁回後餘額不變，學生看得到駁回原因	通過	11

單元測試：金額、日期、收款碼、名冊解析、帳本計算

分組	測試項目	結果	毫秒
金額	千分位與正負號	通過	5
金額	驗證：正整數、上限、餘額	通過	1
金額	事由：必填、最多 50 字	通過	0
日期（台北時間）	跨日以台北時間計算	通過	0
日期（台北時間）	本週一 00:00	通過	0
日期（台北時間）	相對日期	通過	0
日期（台北時間）	日期字串驗證	通過	1
收款碼	8 碼且不含易混淆字元	通過	14
收款碼	正規化手動輸入	通過	0
收款碼	只接受本站付款網址或純代碼	通過	6
名冊解析	支援 account.xlsx 的英文欄名（no/account/passwd/name）	通過	2
名冊解析	支援中文欄名、BOM 與全形字元	通過	1
名冊解析	標示錯誤列：重複帳號、重複座號、缺欄、密碼太短；空白列略過	通過	0

名冊解析	全形轉半形	通過	0
帳本計算	只有已完成交易影響餘額	通過	0
帳本計算	由目前餘額往回推算結餘	通過	0
帳本計算	期間收支	通過	0
帳本計算	對帳找出不一致	通過	1

4B Firebase 模擬器測試（正式版資料層）

與正式環境相同的 Firebase Auth 與 Firestore（本機模擬器），套用專案中的 `firestore.rules`。整合測試與模擬資料庫版使用同一批測試程式，只換資料後端；少數需要控制時鐘或讀取瀏覽器儲存內容的測試僅適用模擬資料庫而略過，對應的保護改由權限規則測試驗證。

端對端（多台裝置）

情境	結果	秒數
Firebase：教師登入 → 匯入名冊 → 批次加點 → 兩台裝置 QR 轉帳 → 核准 → 雙方即時更新 → 小組獎勵 → 刪除帳號	通過	9.9
Firebase：權限——學生無法進入教師後台；重新整理後保持登入	通過	1.0

整合測試：批次停用、啟用與刪除學生帳號（Firebase）

分組	測試項目	結果	毫秒
批次停用 / 啟用與刪除學生帳號	批次停用後無法登入，批次啟用後恢復	通過	1343
批次停用 / 啟用與刪除學生帳號	批次刪除：帳號與登入資料移除，已登入的裝置立即失效	通過	379
批次停用 / 啟用與刪除學生帳號	刪除後交易紀錄保留：對方明細仍看得到姓名與座號；對帳仍一致	通過	530
批次停用 / 啟用與刪除學生帳號	刪除時自動駁回相關的審核中轉帳，並回報被刪除的點數	通過	519
批次停用 / 啟用與刪除學生帳號	刪除學生的收款碼一併失效	通過	440
批次停用 / 啟用與刪除學生帳號	批次刪除全有全無：清單中有不存在的學生時，整批都不刪	通過	254
批次停用 / 啟用與刪除學生帳號	不能用刪除學生的操作刪除教師帳號	通過	244
批次停用 / 啟用與刪除學生帳號	刪除後可用同一帳號重新匯入（例如名冊打錯重建）	通過	389

整合測試：加扣點、批次、小組獎勵、沖正、對帳（Firebase）

分組	測試項目	結果	毫秒
加扣點與批次	個別加點與扣點	通過	1098

加扣點與批次	批次加點：每人一筆交易，共用批次編號	通過	426
加扣點與批次	批次扣點時有人點數不足：整批不執行，並列出不足名單	通過	313
加扣點與批次	金額與項目名稱驗證	通過	180
小組獎勵	並列冠軍 + 亞軍 + 請假排除	通過	556
小組獎勵	同一組不能同時是冠軍和亞軍	通過	287
小組獎勵	同一天重複發放需要確認	通過	389
小組獎勵	整批沖正後可以同日重新發放，餘額全部還原	通過	430
沖正	沖正產生反向交易，原交易標記已沖正	通過	298
沖正	同一筆不能沖正兩次；沖正交易不能再沖正；審核中不能沖正	通過	486
沖正	沖正轉帳：收款人已把點數花掉時，阻擋沖正（避免負數）	通過	429
沖正	沖正轉帳：雙方餘額還原，雙方都看得到沖正紀錄	通過	646
沖正	對帳：經過各種操作後，每位學生交易加總 = 餘額	通過	2569

安全測試：原子性（全有全無，BR-17）（Firebase）

分組	測試項目	結果	毫秒
原子性：中途失敗時資料不變	送出轉帳：交易與收款碼標記都不會只完成一半	略過	0
原子性：中途失敗時資料不變	核准轉帳：不會出現「付款人扣了、收款人沒加」	略過	0
原子性：中途失敗時資料不變	批次加點、小組獎勵、整批沖正	略過	0
原子性：中途失敗時資料不變	業務規則失敗（例如餘額不足）同樣不留下任何部分結果	略過	0

整合測試：帳號、登入、密碼（Firebase）

分組	測試項目	結果	毫秒
帳號與登入	全新系統需要先建立教師帳號，且只能建立一次	略過	0
帳號與登入	建立教師時自動產生 8 個組別與預設加點項目、小確幸	通過	976
帳號與登入	學生以帳號密碼登入；帳號不分大小寫	通過	285
帳號與登入	帳號與密碼的全形英數視同半形（中文輸入法）	通過	262
帳號與登入	模擬資料庫診斷：回報學生數與帳號是否存在於此瀏覽器	略過	0
帳號與登入	密碼錯誤與帳號不存在顯示相同訊息（不透露哪一項錯）	通過	200

帳號與登入	連續輸錯 5 次鎖定 1 分鐘	略過	0
帳號與登入	停用的帳號不能登入，已登入者下一次操作即被拒絕	通過	324
帳號與登入	學生可以修改自己的密碼（需舊密碼）	通過	330
帳號與登入	老師可以重設學生密碼，並解除鎖定（Firebase 版需用管理工具）	通過	193
帳號與登入	匯入名冊：已存在的帳號略過，密碼以雜湊保存（資料庫中沒有明文）	通過	225
帳號與登入	登出後不能再讀取資料	通過	223

安全測試：權限矩陣（對應 SDD 7.2）（Firebase）

分組	測試項目	結果	毫秒
權限：未登入	未登入讀取任何資料皆被拒絕	通過	998
權限：未登入	偽造 session（不存在的 uid）被拒絕	略過	0
權限：未登入	學生竄改 session 的 role 為 teacher 仍無教師權限（以資料庫角色為準）	略過	0
權限：學生不能執行教師操作	所有教師專用方法都拒絕學生	通過	275
權限：學生不能執行教師操作	教師不能使用學生的收付款功能	通過	166
權限：學生之間的資料隔離	學生看不到與自己無關的交易	通過	498
權限：學生之間的資料隔離	學生只拿得到自己的帳戶資料	通過	269
權限：學生之間的資料隔離	學生不能取消別人的收款碼	通過	320
權限：加點項目與小確幸的可見性	學生只看得到「啟用」且「顯示於前台」的項目	通過	641
資料保存	匯出資料不含密碼雜湊	通過	233
資料保存	沒有任何刪除交易的操作介面（帳本只增不刪）；唯一的刪除操作是刪除學生帳號	通過	177

整合測試：QR 轉帳送出與審核（Firebase）

分組	測試項目	結果	毫秒
QR 轉帳：送出申請	收款碼為 8 碼、預設 3 分鐘有效	通過	1768
QR 轉帳：送出申請	送出後為審核中，雙方餘額都不變	通過	598

QR 轉帳：送出申請	付款人與收款人都看得到同一筆交易的完整細目（對象、事由、金額、狀態）	通過	518
QR 轉帳：送出申請	交易資料中不含任何餘額資訊（保護隱私）	通過	544
QR 轉帳：送出申請	收款碼只能使用一次（截圖轉傳無效）	通過	624
QR 轉帳：送出申請	收款碼過期後無法使用	略過	0
QR 轉帳：送出申請	收款人離開頁面時取消收款碼，之後無法使用	通過	496
QR 轉帳：送出申請	不存在或格式錯誤的代碼	通過	456
QR 轉帳：送出申請	手動輸入代碼可忽略大小寫與空白	通過	494
QR 轉帳：送出申請	不能付款給自己	通過	439
QR 轉帳：送出申請	金額必須是正整數且不超過餘額	通過	595
QR 轉帳：送出申請	分類必選、事由必填且最多 50 字	通過	498
QR 轉帳：送出申請	失敗的申請不會消耗收款碼（全有全無）	通過	444
QR 轉帳：送出申請	收款人帳號被停用時無法付款給他	通過	459
QR 轉帳：教師審核	核准後付款人扣點、收款人加點、狀態為已完成	通過	516
QR 轉帳：教師審核	同一筆重複核准只生效一次	通過	509
QR 轉帳：教師審核	兩台教師裝置同時核准同一筆，只成功一次	通過	1655
QR 轉帳：教師審核	多筆申請總額超過餘額：逐筆核准，到餘額不足那筆被擋下	通過	705
QR 轉帳：教師審核	核准所選：依送出順序逐筆處理並回報各自結果	通過	555
QR 轉帳：教師審核	駁回後餘額不變，學生看得到駁回原因	通過	456

安全測試：Firestore 權限規則（直接對規則測試）（Firebase）

分組	測試項目	結果	毫秒
身分與帳戶	未登入：任何讀取都被拒絕	通過	783
身分與帳戶	不在名冊中的登入帳號（自行註冊）無任何權限	通過	277
身分與帳戶	停用的學生：只能讀自己的帳戶，其他一律拒絕	通過	201
身分與帳戶	學生只能讀自己的帳戶	通過	235
身分與帳戶	學生不能修改自己的點數、角色、組別	通過	268
身分與帳戶	教師可以讀寫學生帳戶、刪除學生帳戶；不能刪除教師帳戶；學生不能刪除任何帳戶	通過	302

轉帳申請（學生建立）	合法申請：交易 + 收款碼標記在同一批次 → 允許	通過	156
轉帳申請（學生建立）	只建立交易、沒有標記收款碼 → 拒絕	通過	109
轉帳申請（學生建立）	只標記收款碼、沒有建立交易 → 拒絕	通過	117
轉帳申請（學生建立）	收款碼已使用（截圖重用）→ 拒絕	通過	188
轉帳申請（學生建立）	收款碼已過期（依伺服器時間）→ 拒絕	通過	122
轉帳申請（學生建立）	收款人帳號已停用 → 拒絕	通過	114
轉帳申請（學生建立）	交易上的收款人與收款碼不一致 → 拒絕	通過	119
轉帳申請（學生建立）	冒用他人當付款人 → 拒絕	通過	112
轉帳申請（學生建立）	付款給自己 → 拒絕	通過	134
轉帳申請（學生建立）	直接建立「已完成」的轉帳、或建立加點交易 → 拒絕	通過	155
轉帳申請（學生建立）	金額：0、負數、小數、字串、超過餘額 → 拒絕	通過	294
轉帳申請（學生建立）	事由空白或超過 50 字、分類不在清單 → 拒絕	通過	202
轉帳申請（學生建立）	夾帶餘額快照、偽造建立時間 → 拒絕	通過	145
收款碼	學生只能為自己建立收款碼，且有效期限不超過 10 分鐘	通過	196
收款碼	既有代碼不能被覆寫（碰撞時視為更新而拒絕）	通過	103
收款碼	學生不能列舉收款碼；教師可以	通過	128
收款碼	只有收款人能刪除自己未使用的收款碼（教師亦可）	通過	135
帳本：讀取、審核、沖正、只增不刪	學生只能讀與自己有關的交易	通過	193
帳本：讀取、審核、沖正、只增不刪	任何人都不能刪除交易	通過	129
帳本：讀取、審核、沖正、只增不刪	學生不能修改交易（例如自己核准）	通過	161
帳本：讀取、審核、沖正、只增不刪	教師：可核准審核中的申請；不能改金額或對象；已完成不能改回審核中	通過	216
帳本：讀取、審核、沖正、只增不刪	沖正標記只能設定一次	通過	151
加點項目與小確幸	學生只能讀「啟用且顯示於前台」的項目，查詢必須帶條件	通過	241
加點項目與小確幸	只有教師能新增或修改項目與設定	通過	172

5 安全測試摘要

威脅	驗證方式	結果
未登入存取資料	未登入呼叫各項讀取 API 皆被拒絕；未登入開啟頁面導向登入頁	通過
學生執行教師操作	21 個教師專用方法逐一以學生身分呼叫，全部 PERMISSION_DENIED，且學生點數不變	通過
竄改登入身分（前端）	把瀏覽器中的角色改為 teacher：API 與路由皆以資料庫角色為準，仍無教師權限	通過
偷看他人交易 / 餘額	學生讀取與自己無關的交易被拒；轉帳文件不含餘額資訊	通過
重複使用 / 偽造收款碼	已用、過期、取消、不存在、格式錯誤的代碼皆拒絕；不能付款給自己	通過
金額竄改	0、負數、小數、NaN、字串、超過餘額、超過上限皆拒絕	通過
重複核准 / 並行核准	兩台教師裝置同時核准同一筆，只成功一次	通過
部分完成（原子性）	送出、核准、批次、小組獎勵、整批沖正在寫回前模擬斷線，資料庫內容完全不變	通過
XSS	事由輸入 ，教師與學生頁面皆以純文字顯示、無腳本執行；正式版含 CSP	通過
暴力破解密碼	連續 5 次錯誤鎖定 1 分鐘；錯誤訊息不透露帳號是否存在	通過
密碼外洩	資料庫只存 PBKDF2 雜湊；匯出備份不含雜湊；程式包中無真實名冊	通過
帳本竄改	系統沒有任何刪除交易的操作，錯誤一律沖正；刪除學生帳號時交易紀錄保留、對帳仍一致	通過

5.1 相依套件稽核 (npm audit)

嚴重	高	中	低
1	1	14	0

套件	等級	說明	影響評估
@google-cloud/firestore	moderate	google-gax	僅開發測試工具，不會打包進網站
@google-cloud/pubsub	moderate	@opentelemetry/core	僅開發測試工具，不會打包進網站

@google-cloud/storage	moderate	retry-request ; teeny-request	僅開發測試工具，不會打包進網站
@opentelemetry/core	moderate	OpenTelemetry Core: Unbounded memory allocation in W3C Baggage propagation	僅開發測試工具，不會打包進網站
@vitest/mocker	moderate	Vitest: Path Traversal / Arbitrary File Read via @vitest/mocker Redirect Mock	僅開發測試工具，不會打包進網站
csv-parse	moderate	node-csv: Prototype replacement still reachable via columns path	僅開發測試工具，不會打包進網站
firebase-admin	moderate	@google-cloud/firestore ; @google-cloud/storage	僅開發測試工具，不會打包進網站
firebase-tools	high	@google-cloud/pubsub ; csv-parse ; gaxios ; stream-json ; tar ; uuid	僅開發測試工具，不會打包進網站
gaxios	moderate	uuid	僅開發測試工具，不會打包進網站
google-gax	moderate	retry-request ; uuid	僅開發測試工具，不會打包進網站
retry-request	moderate	teeny-request	僅開發測試工具，不會打包進網站
stream-json	moderate	stream-json: pick/ignore/filter/replace filters are O(depth ²) on nested input — small crafted JSON blocks the event loop for seconds→minutes (DoS)	僅開發測試工具，不會打包進網站

tar	critical	node-tar Vulnerable to Arbitrary File Creation/Overwrite via Hardlink Path Traversal ; node-tar is Vulnerable to Arbitrary File Overwrite and Symlink Poisoning via Insufficient Path Sanitization ; Arbitrary File Read/Write via Hardlink Target Escape Through Symlink Chain in node-tar Extraction ; tar has Hardlink Path Traversal via Drive-Relative Linkpath ; node-tar Symlink Path Traversal via Drive-Relative Linkpath ; Race Condition in node-tar Path Reservations via Unicode Ligature Collisions on macOS APFS ; node-tar applies PAX size override to intermediary GNU long-name/long-link headers, causing tar parser interpretation differential (file smuggling) ; node-tar: Process crash via PAX numeric path type confusion ; node-tar: Decompression/parse DoS via unlimited input ; node-tar: Negative tar entry size causes infinite loop in archive replace ; node-tar: Uncaught Exception DoS via NUL byte in PAX path/linkpath records ; node-tar: Uncontrolled recursion in mapHas/filesFilter allows uncatchable stack-overflow DoS via crafted long-path tar with member selection	僅開發測試工具，不會打包進網站
teeny-request	moderate	uuid	僅開發測試工具，不會打包進網站
uuid	moderate	uuid: Missing buffer bounds check in v3/v5/v6 when buf is provided	僅開發測試工具，不會打包進網站
vitest	moderate	@vitest/mocker ; Vitest: Path Traversal / Arbitrary File Read via @vitest/mocker Redirect Mock	僅開發測試工具，不會打包進網站

正式執行套件 (npm audit --omit=dev) : 0 個漏洞。

6 已知限制與後續事項

項目	說明
正式環境實機驗收	自動化測試使用 Firebase 模擬器；正式環境已完成帳號建立與規則發布，仍需以真實 iPad 實機驗收（相機掃描、加入主畫面、校園網路）。
模擬資料庫版	僅供開發與示範：資料不跨裝置同步，權限檢查在瀏覽器內執行。正式版由 Firestore Security Rules 在伺服器端保護。
App Check 與 API 金鑰限制	尚未啟用（建議上線後設定，見 docs/MIGRATION.md）。目前資料安全由權限規則保障：未列入名冊的帳號無任何權限。
重設 / 刪除登入帳號	免費方案無法在網頁上操作他人的登入帳號，改用老師電腦的管理工具（npm run admin）。
相機掃描	自動化測試環境沒有鏡頭，以「輸入代碼」與「掃描網址直接開啟付款頁」驗證；相機掃描需在真實 iPad 上實機測試。

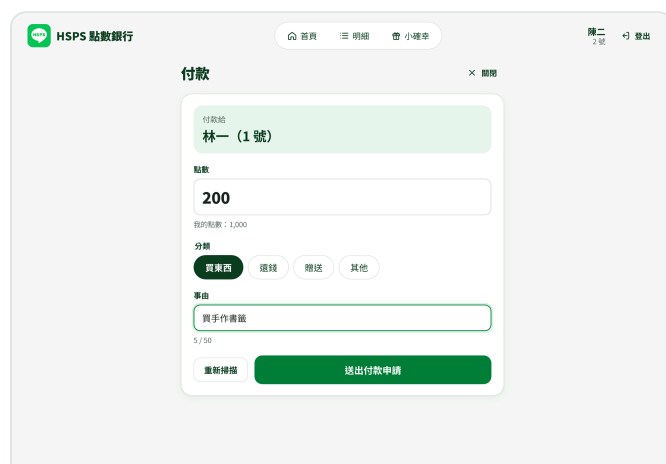
7 畫面截圖（測試過程自動擷取，資料皆為虛構）



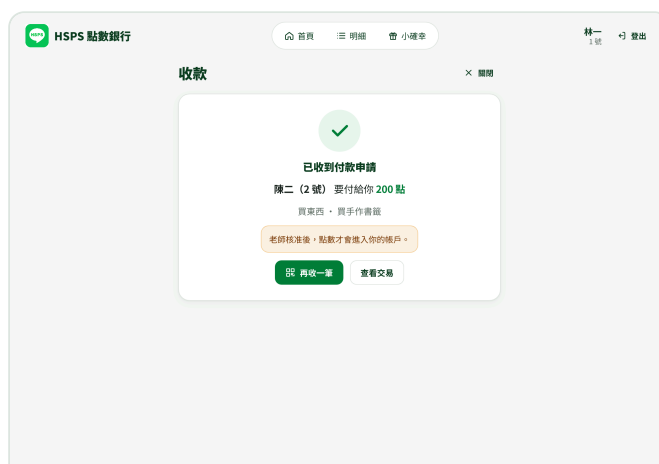
iPad | 學生首頁（核准後）



iPad | 收款：一次性 QR 碼與 8 碼代碼



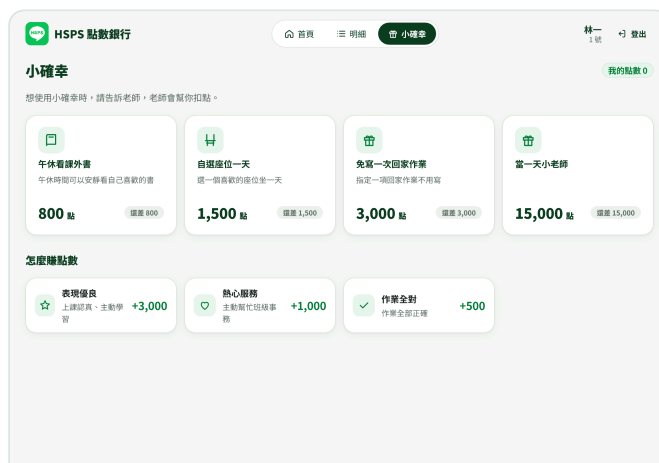
iPad | 付款：金額、分類、事由



iPad | 收款方即時看到付款申請



iPad | 交易詳情（付款方）



iPad | 學生小確幸頁

HSPS 點數銀行

教師儀表板

轉帳審核

學生總覽

加點/批文

小組獎勵

交易紀錄

加點項目與小禮券

分組管理

帳號管理

設定與備份

2026/09/27 · 全班 8 人

早安, 王老師

今日發出

今日扣除

今日小組獎勵

待審核轉帳

今日小組獎勵

最新交易

已建立 8 個帳號

已完成: 8 位學生加 2,000 點

教師電腦 | 教師儀表板

HSPS 點數銀行

教師儀表板

轉帳審核

學生總覽

加點/批文

小組獎勵

交易紀錄

加點項目與小禮券

分組管理

帳號管理

設定與備份

轉帳審核

核准將系統倉庫新增給付款人點數; 付款人扣點、收款人加點與狀態更新需同時完成 (全有全無)。

轉二號 → 林一 (2 號)

最近處理的轉帳

已處理: 8 位學生加 1,000 點

教師電腦 | 教師轉帳審核

HSPS 點數銀行

教師儀表板

轉帳審核

學生總覽

加點/批文

小組獎勵

交易紀錄

加點項目與小禮券

分組管理

帳號管理

設定與備份

小組獎勵

冠軍 (可並列)

亞軍 (可並列)

發放名單

發放紀錄

已建立 8 個帳號

教師電腦 | 小組獎勵 (並列冠軍、請假排除)

HSPS 點數銀行

教師儀表板

轉帳審核

學生總覽

加點/批文

小組獎勵

交易紀錄

加點項目與小禮券

分組管理

帳號管理

設定與備份

學生總覽

一鍵加扣點

交易明細

帳號

已建立 8 個帳號

已完成: 8 位學生加 1,000 點

林一 +3,000 (表現優良)

林一 -300 (忘記帶作業)

教師電腦 | 學生個人頁 (一鍵加扣點)

HSPS 點數銀行

教師儀表板

轉帳審核

學生總覽

加點/批文

小組獎勵

交易紀錄

加點項目與小禮券

分組管理

帳號管理

設定與備份

交易紀錄

轉帳分組

時間

類型

內容

分發/事由

點數

狀態

已建立 8 個帳號

已完成: 8 位學生加 1,000 點

林一 +3,000 (表現優良)

林一 -300 (忘記帶作業)

已沖正

教師電腦 | 交易紀錄 (沖正)

HSPS 點數銀行

教師儀表板

轉帳審核

學生總覽

加點/批文

小組獎勵

交易紀錄

加點項目與小禮券

分組管理

帳號管理

設定與備份

學生總覽

搜尋姓名、帳號或座號

已選 2 人

已停用 2 個帳號

已建立 8 位學生加 100 點

已禁用: 林二 → 林一 50 點

已停用 2 個帳號

教師電腦 | 學生總覽批次操作 (停用 / 刪除)

教師專區

檔案櫃

轉帳審核

學生轉覽

加和點 / 英文

小組獎勵

交易紀錄

加點項目與小確幸

分組管理

帳號管理

設定與備份

王老師

登出

帳號管理

名冊檔案只存在這台電腦的瀏覽器內讀取，不會上傳；密碼以雜湊方式保存，請勿照 account.xlsx 就憑 GitHub。

匯入班級名冊

支援 .xlsx / .csv，欄位：no (序號)、account (帳號)、password (密碼)、name (姓名)，可加欄別，也接受中文欄名「座號、帳號、密碼、姓名、組別」。

選擇檔案

可匯入 8 位

新增 2 列

account.xlsx

第 10 列：帳號 e01 重複

第 11 列：密碼至少 6 碼

座號	姓名	帳號	組別	密碼
1	林一	e01	第 1 組	* - - - - *
2	陳二	e02	第 2 組	* - - - - *
3	王三	e03	第 3 組	* - - - - *
4	張四	e04	第 4 組	* - - - - *
5	李五	e05	第 1 組	* - - - - *
6	黃六	e06	第 2 組	* - - - - *
7	吳七	e07	第 3 組	* - - - - *

匯入 8 位學生

列印帳號小卡

新增單一學生

座號

姓名

帳號

初始密碼 (至少 6 碼)

新增

目前帳號

0 位學生 (0 位傳單)

重設密碼、停用帳號請到「學生轉覽」點閱學生。

前往學生總覽

輸入示範資料 (虛構學生)

教師電腦 | 匯入名冊預覽 (含錯誤列標示)

22 / 22